BinaryRepair MVP

要求、当前差距与完整解决方案

基于公开仓库：https://github.com/leesirleesirlee-star/Binary_Repair

main = 0070103f86366d21642c1e7b87e68a22c294c910

tags = mvp-2026-10-31, v1.0.0

文档日期：2026-11-03

说明：本文整合前两轮讨论的内容，先汇总 MVP/项目成果要求，再逐项对照当前仓库，最后给出完整闭环方案。

目录

- 一、项目与 MVP 的全部要求
- 二、当前 MVP 对照
- 三、问题一一列举
- 四、完整解决方案
- 五、执行顺序与最终门禁
- 六、对 DeepSeek 回复的校正
- 七、一句话结论

一、项目与 MVP 的全部要求

1. 产品目标

一句话目标：对一个已知的 Linux x86-64 ELF CWE-121 栈缓冲区溢出，在没有原始源码的前提下，用两条独立路线修复，并用同一套确定性验收引擎判定结果，最后在本地 GUI 展示和导出可审计证据。

目标用户：软件公司的开发者/安全分析师；持有漏洞二进制、没有源码。五名学生是首轮演示操作者；另有 reviewer 确认修复位置与契约。

最终项目成果：

- AI 二进制漏洞自动修复原型；
- 直接指令补丁 + 局部 C 重编译两条路线；
- 二进制修改、回填与兼容性检查；
- 安全契约 + 自动正确性验证（形式化 + 差分测试）；
- 指定二进制的修复/测试记录、补丁生成/校验方案、评测报告；
- 后续进入真实业务场景验证（下一里程碑，不是 MVP）。

2. 五个 P0 功能

编号	要求	核心验收点

F1	GUI 作业设置与契约审查	接收 ELF、缺陷描述、复现输入、有效测试、环境；输入 hash；拒绝错误架构/畸形/缺失输入；reviewer 确认修复位置与契约
F2	Route A 直接指令修复	基于二进制分析 + 契约生成指令修改；检查编码、边界、放置、跳转；独立副本；不能安全放置则 unsupported
F3	Route B 恢复 C、修复、重集成	从 recovered C 开始；保留原始与人工修改；先做 unchanged round-trip；再安全编辑；编译回填到独立副本
F4	共享验证与明确结果	两候选使用同一测试、期望、契约、分析边界；结构/兼容/行为/有界符号检查；记录域、假设、未解决探索
F5	路线对比与证据导出	并排展示两路线，包括失败/部分结果；改动区域、测试计数、验证/兼容、耗时、人工干预；导出 HTML+JSON 并绑定 hash

3. 六种 outcome

必须严格区分：

```
success_within_scope
unsupported
rejected
inconclusive
error
cancelled
```

- 只有所有 required obligations 通过，才允许 success_within_scope；
- not_run、unknown、timeout、solver unknown、分析错误都不能显示为成功；
- 一条路线成功不等于整个 job 成功；
- 模型解释不是证据。

4. V0–V5 验证阶梯

Gate	要求
V0 身份/前置	hashes、审批、环境、完整必需输入
V1 结构/放置	解析/加载映射、编辑清单、指令/跳转审查、权限、依赖

V2 接口/兼容	签名、栈/寄存器义务、加载器执行、元数据
V3 具体行为	原始复现、invalid oracle、边界、有效套件、副作用
V4 有界符号安全	候选专属模型、输入域、内存访问谓词、探索/求解器记录；函数级，不是全程序
V5 可复现	最终 hash、版本、重放输入、独立队友重放

5. 硬约束

- 两条路线都是硬要求；
- 同一条路线成功不算 MVP 成功；
- 确定性基线不能冒充 AI 路线；
- 同一公开二进制、同一缺陷、同一契约、同一套测试；
- 演示时操作者不需要终端；环境准备除外；
- 5 人 × 5 小时/周 ≈ 25 人时/周；
- 证据诚实：不能把“验收要求”写成“已经达成”；
- 不能从单一样本推断群体成功率。

6. AI 边界

- AI 只提出候选；Route A 模板选择/参数化，Route B 约束性安全编辑；
- AI 不决定验收、不选自己的目标/接口；
- Host 不执行上传/修复后的二进制，不编译模型生成的 C；
- 模型输出必须经过本地严格 schema 校验；
- 模型解释永远不是证据；
- 客户二进制/机密派生内容默认不外传。

7. 安全与工程约束

- Host 只做 GUI、记账、调度、导入证据、计算验收；
- 不可信工作在一回性 Ubuntu x86-64 VM；
- broker 只接受固定操作清单 + 类型化 manifest；拒绝任意 shell 字符串；

- 只绑定 127.0.0.1；一次性 bootstrap token；HttpOnly SameSite=Strict；CSRF；Host/Origin 校验；
- 防路径遍历/符号链接导出；
- 真实二进制执行不能进普通 host/CI 测试；CI 只做 schema/状态/lint/类型/mock worker。

8. 证据与导出要求

必须能导出：original/candidate hash；route/attempt 身份；contract 与 test manifest；完整 edit manifest；Route B raw/normalized/repaired C 与 diff；Route A instruction plan；model/settings/prompt 标识；工具版本；command manifest；obligations；solver/exploration records；counterexamples；HTML + JSON 报告；不包含凭据/机密。

9. 测试要求

- 验收引擎、身份/状态、修复集成、安全验证器；
- 行为：空/最小/典型/最大有效、首个 invalid、更长 invalid；
- AI 集成：空/无效输出、身份错误、provider 失败、预算耗尽、注入串、未授权外传；
- 本地边界：缺 session、跨源 POST、遍历/符号链接导出、恶意 HTML、guest 凭据/网络隔离；
- GUI：设置 → 审查 → 启动 → 对比 → 导出、工作中响应、取消、刷新、未完成阶段可见；
- 独立队友无源码重放。

二、当前 MVP 对照

当前公开仓库：https://github.com/leesirleesirlee-star/Binary_Repair

```
main: 0070103f86366d21642c1e7b87e68a22c294c910
tags: mvp-2026-10-31, v1.0.0
README: accepted with recorded limitations
```

核心判断：这是一个架构完整、证据较丰富、限制披露较好的 candidate；但不是所有 PRD 要求闭环的 full MVP。

对照表

要求	当前状态	判定
F1 GUI/契约审查	GUI、contract、hash、review 流程已实现	基本满足，但目标机 demo 未完全证明
F2 Route A	candidate、Gate5A、V2/V3/V5 证据	基本满足
F3 Route B	recovered C、round-trip、fixed candidate	基本满足，但 source→candidate 证据链不完整
F4 共享验证	V0–V5 有记录，但 V4 是 model-level；没有 live success_within_scope	部分满足，核心 gap
F5 对比/导出	GUI/export 代码与 demo 存在	基本实现，独立 replay 不足
六 outcome	acceptance engine 与测试存在	满足
V0/V1/V2/V3/V5	有多组证据	基本满足
V4	hand-written z3 model, bound 64	不满足最终 candidate ELF 上的有界符号检查
同一 original/defect/contract/test	Gate4/Gate5 记录基本一致	部分满足；Gate5 分裂 successor
两路线都必须成功	没有一次真实 run-level success_within_scope 证据	不满足
独立 reviewer/replay	M4=Lead 同一操作者；F2 waiver	不满足独立性
AI 边界	provider adapter、schema、测试存在	部分满足；没有实际 model call 证据
Host/guest 隔离	worker/broker 有环境注入、固定 argv、隔离记录	基本实现；README 没汇总证据

本地安全	有相关代码/测试	未在验收材料中系统证明
全测试套件	265/262/2 skip/1 fail（环境缺口）	不满足全绿
目标 Ubuntu 运行	start.sh 标注未在目标机验证	不满足目标运行时已验证
证据可审计	clean repo 只有 manifest，raw 在原始归档	部分满足
真实业务场景	明确为下一 milestone	不属于 MVP，但不是已完成项

三、问题一一列举

P0：影响 MVP 结论的核心问题

1. 没有一次真实的 success_within_scope 证据

要求：两条路线都在最终 patched ELF 上通过同一套 required checks。

现状：Gate4 是 unchanged round-trip；Gate5A/5B 是 placement；P2-real 历史 verdict 是 inconclusive/rejected；clean repo 的 ACCEPTANCE.md 讲的是 gate acceptance，不是 live end-to-end repair success。

影响：可以称为“gate/evidence accepted”，不能称为“完成了一次真实端到端漏洞修复”。

2. Gate 4 PASS 容易被误读为“漏洞已修复”

Gate4 的严格范围只是 unchanged round-trip、six cases same、hashes/isolation/revert。它不是修复成功证明。README 表格把 Gate4 PASS 与 Gate5/acceptance 并列，缺少显眼的 Overall: NOT success_within_scope 横幅。

3. V4 不是最终 candidate ELF 上的二进制级有界符号验证

要求：在 actual final candidate ELF 上，函数级、有界，包含 entry redirect/added code。

现状：hand-written z3 model；bound 64；model-level；not binary-level；not whole-program。

影响：V4 作为模型级安全性质可以接受；不能满足最终二进制上的有界符号验证要求；Gate6 写成 accepted via V4 model-level 也有过度概括风险。

4. 两条 Gate5 使用分裂 successor，Route A 没在 Route B successor 下重跑

Route A successor = 90af91ef…；Route B successor = 0066973d…；Route A 未在 Route B successor 下重跑。

准确说法：不是同一 original/defect/contract/test 被破坏，而是同一 successor/同一验证链没有统一；对 Gate5 placement 的可复现性和审计链是实质缺口。

5. M4 verifier 与 Lead 是同一操作者

要求：独立 reviewer/replay，不能只有一个人能解释关键组件。

现状：M4 verifier = Lead same operator；not independent two-person review。

影响：这是与独立验收要求的直接偏差，不是流程瑕疵。

6. Gate4 F2 独立 p2 重跑被 waiver

要求：V5 独立队友重放；F2 是验收清单的一部分。

现状：F2 independent p2 rerun waived；F1 accepted as verification-only JSON + recorder exit 0。

影响：Gate4 通过依赖 waiver，不是独立重跑；对可复现/独立验证是实质削弱。

P1：证据与测试问题

7. P3B 证据与 Gate5B 候选存在错位风险

当前 clean repo：docs/evidence/P3B-SHA256SUMS candidate.elf = 63fcafa6…；Gate5B / acceptance candidate = 208574ab…6717。

影响：P3B manifest 是旧 P3B v5 候选；不能用它证明当前 208574ab 的源码/修复；README 没有显眼标注“P3B 旧候选已作废，不得用于当前 Gate5B”。

8. clean repo 只有 evidence manifest，没有 raw guest evidence

docs/evidence/README.md 明确：raw guest logs、binaries、bundles 仍留在原开发仓库/发布归档。

影响：新仓库本身不能独立 re-hash 全部 raw evidence；审计/复现依赖旧仓库或归档；对独立队友 replay 和可审计证据是缺口。

9. 全测试套件不是全绿

当前记录：265 collected / 262 passed / 2 skipped / 1 failed。失败被解释为 Windows binutils 环境缺口。

影响：可以诚实记录环境缺口；但不能声称所有 required tests 通过；依赖/工具链没有完全冻结。

10. start.sh 未在目标 Ubuntu 上验证

README 明确：start.sh marked unverified on Ubuntu until actually run on target host。

影响：目标运行时没有被实际证明；操作者不用终端完成 demo 的部署路径仍不完整。

11. curated snapshot 丢失完整失败/尝试历史

README：curated snapshot ... extracted from final tag。

影响：对展示有利；对保留每次尝试、失败证据、完整审计轨迹不利；必须明确完整历史/raw archive 的位置。

P2：AI 边界与安全证据

12. 没有实际 model call 证据，不能声称 AI 自主修复

现有证据：binaryrepair_ai provider 存在；Route B replacement_c 是手写/静态 fixed C；P3B evidence 没有 model_calls/prompt/response；没有“模型生成此候选”的绑定。

影响：可以说 AI-assisted development / AI candidate layer；不能声称 AI 自主发现并修复了该漏洞。

13. AI 边界测试没有在验收材料中汇总

代码/测试里存在 tests/test_provider.py、tests/test_provider_failures.py、tests/test_ai_boundary_contract.py；但 README/ACCEPTANCE 没有给出 prompt injection、空/无效输出、未授权外传、预算耗尽、工具/动作边界、实际通过结果。

影响：不能从 README 证明 AI 边界要求已满足；需要补一份测试结果索引。

14. 本地安全/broker 隔离证据没有汇总

代码有 loopback、token、CSRF/Origin、worker env、broker 固定 argv、guest isolation 记录；但 README 没有集中展示缺 session、跨源 POST、路径遍历/符号链接、broker 拒绝 shell、输出大小/时间/文件系统限制、guest 凭据/网络隔离。

影响：实现可能存在，但验收材料不足。

15. 成本/预算控制没有展示

要求：provider 失败、额度耗尽、预算上限行为。现状：有 provider failure tests；README 没有成本/预算验收证据。

P3：文档与表述

16. Accepted with recorded limitations 与 PRD 完成清单不一致

PRD 的 MVP Completion Checklist 仍是未勾选状态；仓库 acceptance 却写 accepted with limitations。需要明确 accepted = gate/evidence acceptance，not = all PRD completion checklist items satisfied。

17. README 表格缺少整体未达 success_within_scope 的显眼声明

建议在 MVP status 表最上方加：Overall: NOT a live success_within_scope. This is gate/evidence acceptance with recorded limitations。

18. 同上输入问题需要精确表述

DeepSeek 说“分裂 successor 违反 same input”略有过度。更准确：original/defect/contract/test 是同一套；Gate5 successor 分裂，Route A 未在 Route B successor 下重跑；这是验证链/可复现性问题，不是 original input 不同。

四、完整解决方案

完整方案分两条线：1）立即做 truthful release；2）工程闭环。不要把 candidate 说成 full MVP。

P0：先修表述与证据链

1. README 顶部加整体结论横幅

在最顶部加：Overall acceptance: NOT a live success_within_scope. This repository records gate/evidence acceptance with limitations. Gate 4 PASS is unchanged round-trip only. V4 is model-level, bound 64。

并在表格下方直接列 5 条最硬限制：

- No live both-route success_within_scope is recorded.
- V4 is not binary-level.
- M4 and Lead are the same operator.
- Gate 4 F2 independent p2 rerun was waived.
- Full suite is not green on every environment.

完成标准：只看 README 前 30 行，就能知道这不是 full success。

2. 建立 REQUIREMENTS-MATRIX.md

新增 docs/acceptance/REQUIREMENTS-MATRIX.md，逐条映射 F1—F5、V0—V5、六 outcome、AI boundary、broker isolation、local security、tests、target runtime、evidence/replay。每行必须有 requirement、status、evidence path、test command、owner。

完成标准：任何“我们满足了吗”都能在一张表里查到。

3. 统一证据索引，废弃旧 P3B 候选

保留旧文件作历史；重命名或加标题 P3B-v5-SUPERSEDED-SHA256SUMS；新增 docs/evidence/CANONICAL.md，明确 Current Route B candidate 208574ab…6717、Current Route B evidence Gate5B、P3B v5 63fcafa6… historical/superseded。README 只引用 canonical index。

完成标准：搜索 63fcafa6 只能看到 superseded，不能看到当前 acceptance 引用。

4. 补 source → candidate 绑定

新增 docs/acceptance/SOURCE-TO-CANDIDATE.md：fixed_badSink_existing_imports.c SHA-256 a2e4ff8f…；compile recipe/flags/Patcherex2/guest env；candidate 208574ab…；说明是否 byte-identical，若不一致记录差异。

完成标准：看到 candidate 208 时，能追溯它来自哪份 C、哪套工具链、哪次 build。

P0：做一次真实 end-to-end success

5. 固定一套可运行环境

目标：Ubuntu 24.04 x86-64、Python 3.11/3.12、pyelftools、capstone、binutils、Ghidra/JDK、Patcherex2、angr/Claripy/Z3、Chromium。执行 python -m venv .venv；pip install -r requirements.txt；启动 controller/worker/GUI。

当前 start.sh 明确未在 Ubuntu 目标机验证，必须实际跑一次。完成标准：start.sh 在目标 Ubuntu 上成功启动 GUI，无需操作者手动改路径/export。

6. 跑一次完整 job

用同一份 original.elf、defect description、reviewed contract、valid/invalid tests，走 create job → approve contract → start run → Route A/B candidates → worker → acceptance → p2_acceptance。

```
python tools/p2_acceptance.py --job-id <id> --base-url http://127.0.0.1:8000
```

要求：phase=finished；synthetic=false；Route A success_within_scope；Route B success_within_scope；run-level success_within_scope。任一路线 inconclusive/rejected，记录 failing_obligation，修复后重跑；不得把 gate evidence 说成 success。

完成标准：一份真实 job 记录，both routes success + raw p2 log + candidate hashes + obligation table。

P0：V4 升级或明确降级

7. 选择 V4 路线

方案 A：升级为最终 candidate 上的函数级有界检查：actual final candidate ELF；包含 entry redirect；包含 added code；函数级输入域；明确 memory predicates；记录 SAT/UNSAT/unknown；校准 original 和 deliberately defective candidate；不允许 hook 替代关键操作。新增 docs/acceptance/V4-BINARY.md。

方案 B：不升级，则所有地方写 V4 = model-level PASS, bound 64，NOT binary-level，NOT whole-program，且不能声称满足最终 ELF 上的有界符号验证。

完成标准：要么有 binary-level V4 evidence；要么全仓库统一写 model-level，且 REQUIREMENTS-MATRIX 标为 partial。

P0：统一 Gate5 successor 链

8. Route A 在 Route B successor 下重跑

当前 Route A successor 90af91ef…、Route B successor 0066973d…，Route A 未在 Route B successor 下重跑。方案：用 Route B successor + Route A probe 重跑一次 Route A，生成新的 Gate5A evidence，更新 record；或明确记录 Gate5A/B separate successor 是 known validation-chain deviation。

完成标准：同一 successor 链，或明确 scoped deviation；Gate5A/B evidence 不再被误读为同一次部署。

P0：独立性

9. M4 与 Lead 分离

要求真正的第二个人独立 replay、独立填写 M4 verifier 行；Lead 只做批准，不做 verification。无法做到则 acceptance 明确写 not independent two-person review，且不能声称满足独立复核要求。

10. F2 不再 waiver（或明确记录）

由独立 M4 重跑 p2，保留 raw log、exit code、obligations；如果仍 waiver，必须在 requirement matrix 标为 partial，不得说 V5 独立 replay 已完成。

P1：测试与安全边界

11. 冻结依赖并跑全测试

固定 requirements lock；安装 pyelftools/capstone/binutils/browser；跑 pytest --ignore=tests/e2e 和 pytest tests/e2e；保存日志；每个失败分类 product bug / environment gap / test issue。完成标准：全绿，或每个 not_run 都有环境说明且不影响 required claim。

12. 补 broker/isolation 测试证据

覆盖固定 argv、无 shell、拒绝 caller command、缺 original/contract 不 spawn、contract hash mismatch 不 spawn、bundle 已存在不重复调用、uid 1003、CapEff=0、NoNewPrivs=1、netns empty、no egress、输出大小/时间/文件系统限制。保存 command、raw log、pass/fail。

13. 补 AI 边界测试证据

覆盖 empty/invalid JSON、wrong identity、provider timeout/rate limit/balance、budget exhaustion、prompt injection、unauthorized data transfer、schema violation、model cannot execute/compile。现有 tests/test_provider.py、tests/test_provider_failures.py、tests/test_ai_boundary_contract.py；结果汇总进 docs/acceptance/AI-BOUNDARY.md。

14. 补本地安全测试证据

覆盖 loopback only、bootstrap token、missing session、CSRF、Host/Origin、path traversal、symlink export、malicious HTML、cookie SameSite/HttpOnly。新增 docs/acceptance/LOCAL-SECURITY.md。

15. 补成本/预算证据

覆盖 per-job budget、provider failure、budget exhaustion、model call recording；输出 docs/acceptance/COST-CONTROL.md。

P1：证据与 replay

16. 把 raw evidence 纳入可获取位置

二选一：把 raw bundles 放入 release artifact；或提供固定下载地址/校验方式。docs/evidence/README.md 必须写 manifest path、raw archive URL、SHA-256、replay command。

17. 独立队友 replay

第二人从 clean checkout 按 README 启动，重新 hash、重跑六例、重跑 acceptance、记录 exit code。输出 docs/acceptance/INDEPENDENT-REPLAY.md。完成标准：不是本人；有独立记录；有 hash 和日志。

P2：文档与发布

18. 修正 README/acceptance 的措辞

- Gate PASS ≠ repair success；
- Gate4 = unchanged round-trip；
- V4 = model-level；
- candidate ≠ full MVP。

19. 处理已有 tag

新仓库已有 mvp-2026-10-31、v1.0.0。如果它们被当作 full acceptance，但存在上述 gap，不能静默移动 tag。方案：保留 tags 作历史；新增 ACCEPTANCE-ADDENDUM/ERRATA；或创建新的 full tag 仅在所有 gap 关闭后；不要覆盖旧 tag。

20. 最终发布门禁

只有全部满足才创建 full tag：both routes success_within_scope；V4 binary-level or scope-approved；M4 independent；F2 not waived；full suite green；broker/AI/local security/cost evidence；P3B/Gate5B canonical；target runtime verified；README limitations explicit。否则保持 candidate 标签。

五、执行顺序与最终门禁

今天/本周 P0

- README 顶部 truthful 横幅；
- 建 REQUIREMENTS-MATRIX；
- 统一 P3B/Gate5B 证据；
- 补 source→candidate 文档；
- 跑一次真实 p2，确认是否 success；
- 决定 V4：升级或明确降级；
- 统一 Gate5 successor 链。

下一阶段 P1

- 独立 M4 replay；
- 全测试环境；
- broker/AI/local security/cost 证据；
- 独立队友 replay；
- raw evidence 归档。

最后 P2

- 修正所有文档表述；
- Lead 审阅；
- 才创建 full acceptance tag。

最终判断

你们现在不是“没有 MVP”，而是：有完整架构、GUI、两路线、验收引擎、证据体系；但没有把所有 PRD 要求闭环成一次真实 full success。

正确的完整解决方案是：先把 candidate 和 full MVP 的边界说清楚；再补真实 success、V4 强度、独立性、全环境测试和 canonical evidence；最后才允许 full tag。如果时间和环境不允许补齐，则应明确选择交付 candidate / integration demonstration，而不是把 candidate 说成 full MVP。

六、对 DeepSeek 回复的校正

需要保留的判断

- 没有 live success_within_scope 证据；
- V4 只是 model-level；
- M4/Lead 同一人；
- F2 waiver；
- 全测试套件不全绿；
- P3B 63fc 与 Gate5B 208 的错位风险；
- start.sh 未验证；
- curated snapshot 的审计限制。

需要校正的判断

1）README 原文 No real pipeline run reached success_within_scope：当前 README 没有这句原文。结论仍成立，但不要伪造引用。

2）分裂 successor 违反 same input：不是同一 original/contract/test 被破坏；准确是 Gate5 验证链不统一、Route A 未在 Route B successor 下重跑。

3）README 没有 AI/安全测试证据：代码和测试文件存在；问题是验收材料没有汇总结果，不等于完全没实现。

4）Gate4 PASS 被误读：README 有 limitations，但表格确实缺少整体横幅；这是表述问题，不是 Gate4 记录本身造假。

七、一句话结论

这个仓库已经是一个架构完整、证据丰富、限制披露较好的 AI-assisted binary repair MVP candidate；但它还不是所有 PRD 要求全部闭环的 MVP。最大的问题不是代码骨架，而是：没有真实

端到端 success、V4 不是二进制级、独立复核不足、全测试未全绿、证据链存在旧候选错位，以及若干安全/AI 边界证据没有汇总到验收层。